

Now on this settings page I showed you

in the previous lecture,

there are more settings that are worth a closer look.

For example, you can check whether GitHub Actions

should be able to automatically create or approve

Show more 



GitHub Actions Repository Settings – Security Explained

The **GitHub Actions Settings** page contains several important security options that help control how workflows run and what permissions they have. These settings are especially important for public repositories and production projects.

1. Allow GitHub Actions to Create or Approve Pull Requests

GitHub lets you decide whether workflows can automatically:

- Create Pull Requests
- Approve Pull Requests
- Merge Pull Requests

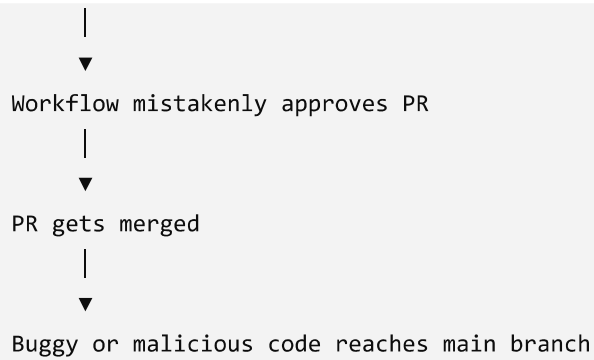
Why is this risky?

Imagine your workflow contains a bug or malicious code.

If GitHub Actions is allowed to approve PRs automatically:

Developer
|
▼
Workflow runs





A workflow could accidentally approve code that should have been reviewed by a human.

Recommended

For most projects:

- ✅ Disable automatic PR approval.

Require humans to:

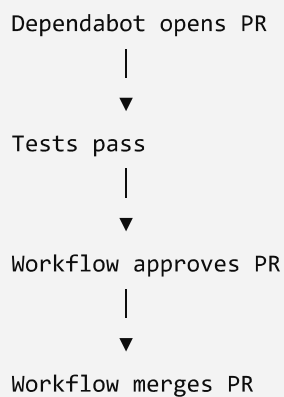
- Review code
- Approve PRs
- Merge changes

When to Enable

You may enable it if:

- your repository is highly automated
- workflows are well tested
- bots manage dependency updates
- you trust your CI/CD pipeline

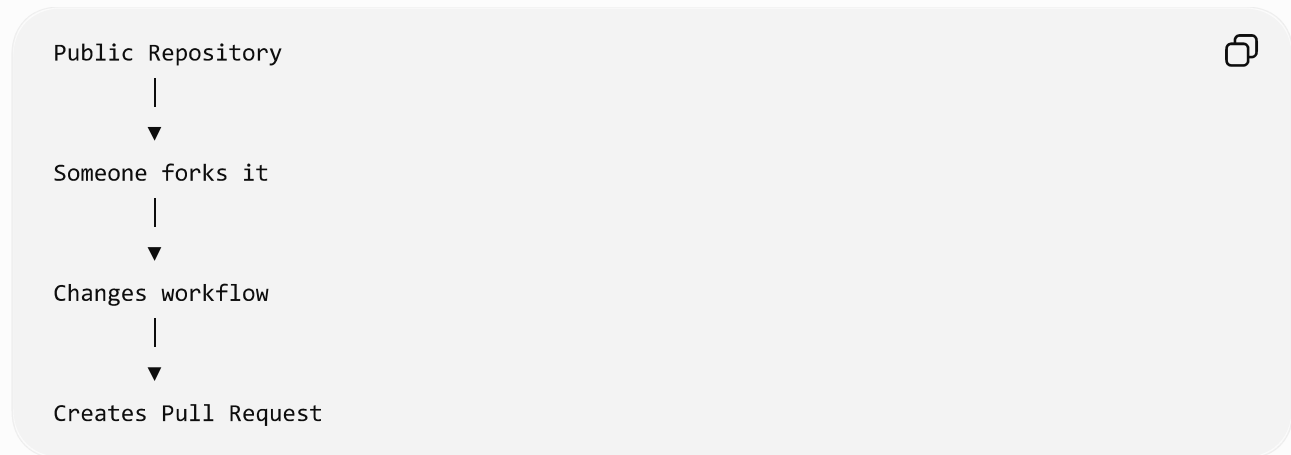
Example:



2. Approval for Pull Requests from Forks

One of the biggest GitHub security risks comes from **forked repositories**.

Anyone can:



The workflow might now contain:

- malicious shell commands
- secret stealing
- crypto miners
- modified GitHub Actions

If GitHub automatically executed these workflows, attackers could potentially abuse your CI environment.

GitHub provides approval options

Option 1

Require approval for:

First-time contributors

Good balance between security and convenience.

Option 2

Require approval for:

New GitHub users

Accounts with little or no GitHub history.

Useful because fake accounts are commonly used for attacks.

Option 3

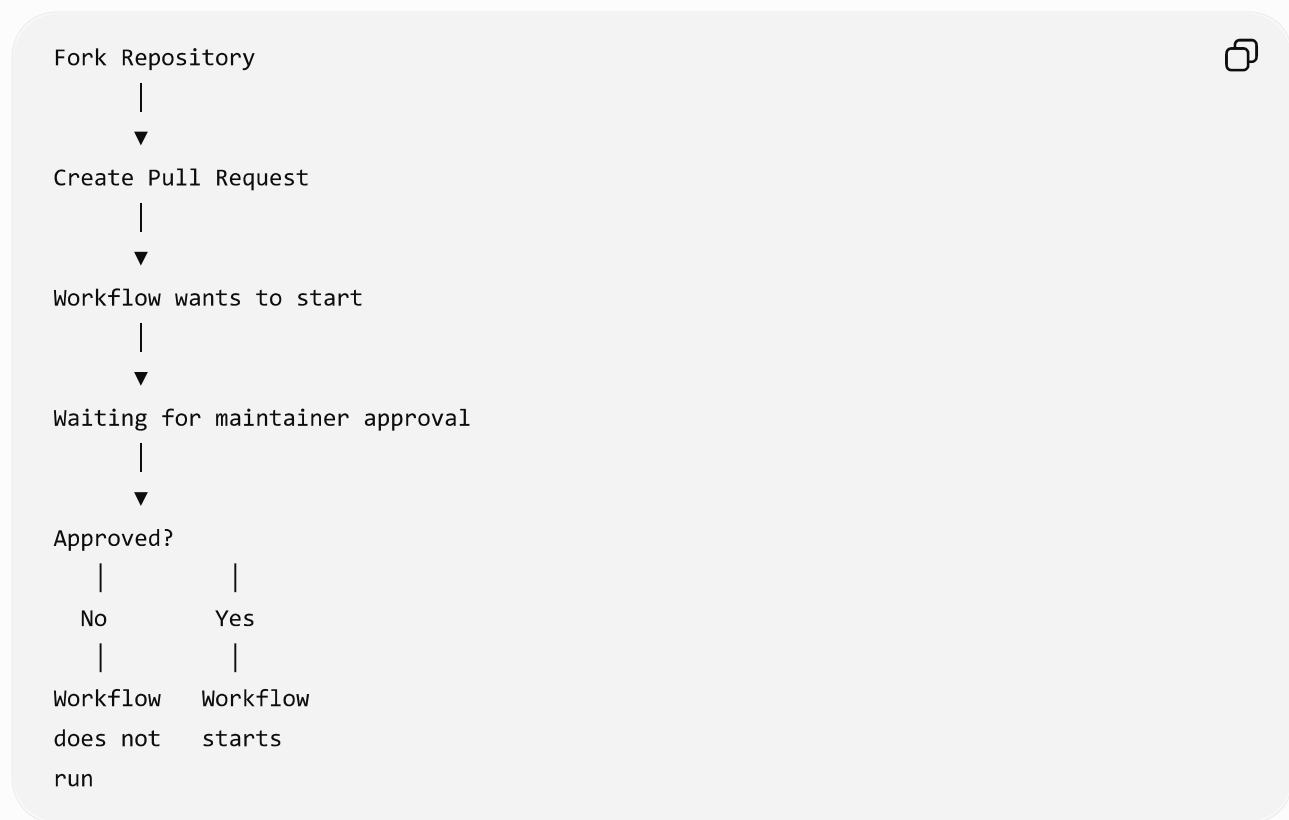
Require approval for:

All outside collaborators

Most secure option.

Every external contributor requires manual approval before workflows run.

Example flow:



3. Restrict Which GitHub Actions Can Be Used

GitHub lets you control which Actions developers are allowed to use.

Options include:

Allow all actions

Marketplace Actions
Community Actions
Organization Actions
Private Actions



Most flexible.

Also the highest risk.

Allow only local actions

Only actions stored inside your own repositories.

Example:

```
my-company/  
  reusable-action/  
  
Workflow  
  
uses:  
  my-company/reusable-action
```



This reduces supply chain risk because you fully control the code.

Allow only verified creators

GitHub also lets you trust only verified publishers.

Example:

```
actions/*  
github/*  
azure/*  
docker/*
```



Safer than allowing everything.

Disable Actions Completely

Repository



×

No workflows

No CI

No CD

Useful for repositories that don't need automation.

Why Restrict Actions?

Every action is executable code.

Example:

⌕ YAML



```
uses: someone/random-action@v1
```

This downloads and executes someone else's code.

If that action becomes compromised, your workflow becomes compromised too.

Security Recommendation

Instead of:

⌕ YAML



```
uses: some-random/action@latest
```

Use:

⌕ YAML



```
uses: actions/checkout@v4
```

or

⌕ YAML



uses: my-org/custom-action@v2

Even better, pin to a commit SHA:

</> **YAML**



uses: actions/checkout@8ade135...

This prevents unexpected changes from future releases.

Best Practices

- Disable automatic PR approval unless it is truly required.
- Require manual approval for workflows triggered by forked repositories.
- Allow only trusted or organization-owned GitHub Actions.
- Pin actions to specific versions or commit SHAs instead of using `latest`.
- Regularly audit the actions used in your workflows.
- Keep workflows and third-party actions up to date.

Summary

Setting	Purpose	Recommended
Allow GitHub Actions to create/approve PRs	Lets workflows manage PRs automatically	Disable unless your automation is fully trusted
Approval for workflows from forks	Protects against malicious pull requests	Enable manual approval (especially for public repositories)
Restrict allowed Actions	Controls which actions workflows can execute	Allow only trusted or organization-owned actions
Disable Actions	Turns off GitHub Actions completely	Use only if the repository does not require CI/CD

These settings form an important part of securing GitHub Actions. They help prevent accidental merges, reduce the risk of malicious contributions from forked repositories, and protect your CI/CD pipeline from untrusted third-party code.

https://github.com/piyalidas10/Git-Tutorials/settings/actions
explain each sections

The page you shared is your repository's **GitHub Actions** → **General** settings:

Repository: piyalidas10/Git-Tutorials

Settings → **Actions** → **General**

Official documentation:

[GitHub Actions Settings Documentation ↗](#)

Below is a section-by-section explanation of everything you'll typically see on that page.

1. Actions Permissions

This section controls **whether GitHub Actions can run** and **which Actions are allowed**.

You'll typically see options like:

Option 1: Disable Actions

o Disable Actions



No workflows can run.

Example

.github/workflows/



CI ✖
Deploy ✖
Tests ✖

Use when:

- Repository is archived
- No CI/CD needed

Option 2: Allow local actions only

- o Allow OWNER actions only



Only Actions stored in your own account can run.

Example

uses: piyalidas10/my-action@v1 



uses: actions/checkout@v4 

Very secure but restrictive. [GitHub Docs](#)

Option 3: Allow selected Actions

- o Allow selected actions



You choose exactly which Actions are allowed.

Example:

actions/*
github/*
docker/*



Everything else is blocked.

Good for enterprise environments.

Option 4: Allow all Actions and reusable workflows (Default)

- o Allow all actions



Examples:

actions/checkout
actions/setup-node



docker/build-push-action
codecov/codecov-action

This is the easiest option for learning and open-source projects.

For production repositories, review third-party Actions before using them. [GitHub Docs](#)

Require Actions to be pinned

You may also see:

☒ Require actions to be pinned



Instead of

`</> YAML`



`uses: actions/checkout@v4`

GitHub requires

`</> YAML`



`uses: actions/checkout@8ade135...`

Why?

Tags can move.

Commit SHAs never change.

This prevents supply-chain attacks. [GitHub Docs](#)

2. Fork Pull Request Workflows

This controls workflows coming from **forked repositories**.

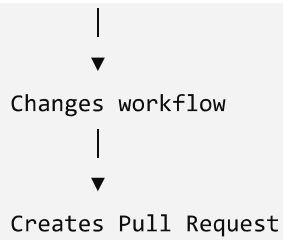
Example

Your Repository



Someone forks it





GitHub protects you because the workflow could contain malicious code.

Possible approval settings include:

First-time contributors

Require approval only once



Alice
First PR
↓



Needs approval

Second PR

Runs automatically

Good balance.

New GitHub users

Only newly created GitHub accounts require approval.

Useful against spam accounts.

All outside collaborators

Every external contributor requires approval.

External User



↓

Approval Required



Workflow Starts

Safest option for public repositories. [GitHub Docs](#)

3. Workflow Permissions (GITHUB_TOKEN)

Every workflow automatically receives a special token:

GITHUB_TOKEN



This token allows the workflow to communicate with GitHub.

Read Repository Contents

contents: read



Workflow can

☒ Clone code

Example

`</> YAML`



```
uses: actions/checkout@v4
```

No write access.

Read and Write Permissions

contents: write



Workflow can

- Push commits
- Create releases

- Create tags
- Upload artifacts

Example

</> YAML



```
git push origin main
```

Works only with write permission. [GitHub Docs](#)

Security Principle

Always follow the **Principle of Least Privilege**.

Instead of giving every workflow full write access:

</> YAML



```
permissions:  
  contents: read
```

Grant only the permissions required for that workflow.

4. Allow GitHub Actions to Create and Approve Pull Requests

This controls whether workflows may automatically:

- Create PRs
- Approve PRs
- Merge PRs

Disabled:

Workflow



↓

Cannot approve PR

Enabled:

Workflow



↓

Approve PR

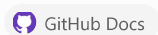
↓

Merge PR

Useful for:

- Dependabot
- Release automation
- Version bump bots

Most personal projects should leave this disabled unless there's a clear automation need.



5. Access (Private Repositories Only)

If your repository is private, you'll see an **Access** section.

Example

Private Action Repository



↓

Other Private Repository

↓

Can reuse workflows

Options:

Not Accessible



or

Accessible from repositories owned by you

Useful when you create reusable workflows or custom Actions.

6. Cache Settings (Paid Plans)

GitHub Actions can cache dependencies.

Example:

Without cache

```
npm install
```

3 min



With cache

```
Restore cache
```

20 sec



Typical settings:

- Cache retention (days)
- Cache size limit

GitHub automatically removes older caches when limits are reached. [GitHub Docs](#)

7. Artifact and Log Retention

Every workflow can upload:

- Build outputs
- Test reports
- Coverage reports
- Logs

Example

```
Workflow
```

↓

```
Build
```

↓

```
Artifact.zip
```



↓

Stored for 90 days

You can configure how long these are kept.

Typical values:

- Public repositories: 1–90 days
- Private repositories: up to 400 days (subject to plan and organization limits).

 GitHub Docs +1

8. Reusable Workflows

GitHub also supports reusable workflows.

Instead of duplicating CI across repositories:

Repo A



calls

Common Workflow

Repo B

calls

Common Workflow

Repo C

calls

Common Workflow

This makes maintenance easier because updating the shared workflow benefits every repository that uses it.

Recommended Settings for Your Git-Tutorials Repository

Since your repository is a **public learning/tutorial repository**, these settings are a sensible starting point:

Setting	Recommendation	Why
Actions permissions	✓ Allow all actions and reusable workflows	Needed for learning and trying community Actions
Require pinned Actions	✓ Enable when possible	Improves supply-chain security
Fork pull request approval	✓ Require approval for first-time contributors	Protects against malicious workflows
Workflow permissions	✓ Read repository contents by default	Grant write permissions only where necessary
Allow GitHub Actions to create/approve PRs	✗ Disabled	Avoid accidental approvals or merges
Cache settings	✓ Enable if available	Faster workflow execution
Artifact retention	30–90 days	Good balance between debugging and storage

These recommendations align with GitHub's guidance for secure GitHub Actions usage while keeping the repository practical for CI/CD experimentation. [GitHub Docs](#)

       Sources